PROYECTO RENIEC - BID
Mejoramiento del acceso a los servicios de registros civiles e identificación de calidad a nivel nacional

ESTÁNDAR DE DESARROLLO SEGURO

Mejoramiento de Acceso a los Servicios de Registros Civiles e Identificación de Calidad a Nivel Nacional (Contrato de Préstamo BID № 4297/OC-PE)

Componente 3: Incorporación de tecnologías para la prestación de los servicios

RENIEC
REGISTRO NACIONAL DE IDENTIFICACIÓN Y ESTADO CIVIL

Elaborado por:

Ing. Jarol Adolfo Bastidas Orihuela
Especialista en Arquitectura de Soluciones Senior

Historial de modificaciones del Estándar de Desarrollo Seguro

Versión	Fecha	Modificaciones	Preparado/Revisado por
1.0	30/05/2024	Versión inicial	Jarol Adolfo Bastidas Orihuela
1.1	12/08/2025	Versión actualizada	Jarol Adolfo Bastidas Orihuela

REPÚBLICA DEL PERÚ
FIRMA DIGITAL

Firmado digitalmente por:
BASTIDAS ORIHUELA JAROL ADOLFO FIR 40561133 hard
Motivo: Soy el autor del documento
Fecha: 15/09/2025 09:40:55-0500

MIGUEL ÁNGEL MARTÍNEZ LA ROSA
Jefe de la Unidad de Ingeniería de Software
REGISTRO NACIONAL DE IDENTIFICACION Y ESTADO CIVIL

Firmado digitalmente por:
MARTINEZ LA ROSA Miguel Angel FAU 20295613620 soft
Motivo: En señal de conformidad
Fecha: 15/09/2025 14:24:16-0500

1. OBJETIVO

Establecer los requisitos mínimos y prácticas obligatorias de desarrollo seguro para crear servicios, arquitecturas, software y sistemas que protejan la confidencialidad, integridad y disponibilidad de la información del RENIEC, alineados al SGSI (ISO/IEC 27001) y a la normativa vigente.

2. ÁREA RESPONSABLE

Oficina de Tecnologías de la Información

i. **Unidad de Ingeniería de Software:** Es el responsable de la definición del estándar de desarrollo seguro, de mantenerla actualizada y de verificar el cumplimiento del estándar.
ii. **Seguridad de la Información:** Asesora, audita y gestiona excepciones.
iii. **Líder del Equipo de Desarrollo:** Es el encargado de asegurar el cumplimiento de los principios, lineamientos y evaluación que se definen en el presente documento.

3. ALCANCE

El presente estándar aplica para su uso en la implementación del Sistema Integrado de Identificación y Registro Civil (SIIRC) y constituye además una guía de buenas prácticas para el desarrollo y mantenimiento de los sistemas de información a cargo de la Unidad de Ingeniería de Software (UIS).

4. DEFINICIONES Y SIGLAS

- **CI/CD:** Integración Continua / Entrega Continua.
- **Fuzzing:** Técnica de pruebas que envía entradas aleatorias para forzar errores y descubrir vulnerabilidades.
- **Hardening:** Proceso de reducir la superficie de ataque de sistemas (SO, contenedores, Kubernetes, BD, redes, aplicaciones) mediante configuraciones seguras por defecto, eliminación de componentes innecesarios y aplicación de controles mínimos necesarios.
- **JSON Lines (NDJSON):** Formato de registro: un objeto JSON por línea.
- **KDF:** Key Derivation Function (función de derivación de claves).
- **KMS/HSM:** Servicio de gestión de claves / Módulo de seguridad hardware.
- **MFA:** Autenticación multifactor.
- **MTTR:** Mean Time To Repair / Recover / Restore. Tiempo promedio para restaurar el servicio tras un incidente, desde la detección hasta la recuperación. Fórmula simple: MTTR = (suma de tiempos de recuperación de incidentes) / (número de incidentes).

- **OIDC/OAuth 2.0:** OpenID Connect / Marco de autorización.
- **Postmortems:** Análisis tras un incidente para aprender y mejorar. Incluye: resumen/impacto, línea de tiempo, causa raíz (p. ej., 5 Porques), qué funcionó/qué no, acciones correctivas/preventivas con responsables y fechas, y seguimiento.
- **RBAC/ABAC:** Control de acceso por roles / por atributos.
- **SAST/DAST/IAST:** Static Application Security Testing / Dynamic Application Security Testing / Interactive Application Security Testing (Análisis estático / dinámico / interactivo de seguridad de aplicaciones).
- **SBOM:** Software Bill of Materials (inventario de componentes).
- **SLA /SLO/SLI:** Service Level Agreement / Service Level Objective / Service Level Indicator (Acuerdo de Nivel de Servicio / Objetivo de Nivel de Servicio / Indicador de Nivel de Servicio).
- **Zero Trust:** Modelo que asume que ningún actor o dato es confiable por defecto.

5. REQUISITOS

5.1 Separación de entornos (desarrollo, prueba y producción)

- Los entornos deben estar segregados (redes, cuentas de nube, bases de datos, credenciales y secrets).
- Queda PROHIBIDO compartir bases de datos o secrets entre entornos; cada entorno tendrá credenciales distintas y privilegios mínimos.
- Los datos de producción no podrán usarse en desarrollo/prueba salvo copias anonimizadas/enmascaradas aprobadas por Seguridad.
- La promoción de cambios se realizará exclusivamente vía CI/CD; no se permiten cambios manuales en producción.
- Mantener paridad de entornos (configuración/versión) y congelamiento de dependencias por ambiente.

5.2 Seguridad en el ciclo de vida del desarrollo

5.2.1 Metodología de desarrollo segura

- Adoptar una metodología (ágil o híbrida) con actividades de seguridad integradas: identificación de requerimientos de seguridad, modelado de amenazas, criterios de aceptación de seguridad y revisiones de diseño.

- El enfoque Zero Trust aplica: el cliente no es confiable; decisiones se basan en datos del lado del servidor y tokens verificados.

5.2.2 Pautas de codificación segura

- Cumplir el Estándar de Codificación Segura institucional (por lenguaje).
- Validación de entradas en backend, codificación de salidas por contexto, manejo seguro de errores, CSP (Content Security Policy), protección CSRF (Cross-Site Request Forgery), y uso de APIs parametrizadas (SQL/NoSQL).

5.3 Requisitos de seguridad en especificación y diseño

- Privacidad y seguridad desde el diseño (privacy/security by design): clasificación de datos, matriz de acceso (roles/atributos), cifrado en tránsito/en reposo, logs de auditoría requeridos y retención.
- Definir SLO/SLI de seguridad y KPIs (tasa de vulnerabilidades, MTTR de parches).
- Identificar controles compensatorios para riesgos residuales.

5.4 Puntos de control de seguridad en proyectos (gates)

- Inicio: definición de requerimientos de seguridad y plan de pruebas; NO GO si no se identifican responsables y riesgos.
- Diseño: modelado de amenazas y revisión de arquitectura; NO GO si hay riesgos Altos sin mitigación.
- Construcción: evidencia de SAST, análisis de dependencias y secret scanning sin hallazgos críticos; NO GO si fallan.
- Pre-producción: DAST/IAST, hardening, SBOM, escaneo de contenedores/IaC y pruebas de regresión; NO GO si hay críticos abiertos.
- Liberación: despliegue verificado con firmas y políticas de admisión; rollback probado.
- Operación: gestión de vulnerabilidades y parches con SLA; postmortems y mejora continua.

5.5 Pruebas de sistema y seguridad

- Pruebas funcionales (unitarias, integración) con cobertura acordada.
- Pruebas de seguridad: SAST, DAST/IAST, fuzzing (cuando aplique) y pruebas de penetración al menos por hito mayor o cambios críticos.

- Pruebas de regresión automatizadas antes de cada liberación.
- Evidencia en CI/CD: reportes firmes, trazables al commit/tag liberado.

5.6 Repositorios seguros para código y configuración

- Repositorios privados y segmentados por dominio; acceso por roles.
- Branch protection (revisiones obligatorias, status checks, prohibir force push a ramas protegidas).
- Firmar commits/tags (GPG/Sigstore) y firmar artefactos del build.
- Habilitar secret scanning y dependabot/equivalente.
- Prohibido API keys/secretos en repos; usar Secret Manager.

5.7 Seguridad en el control de versiones

- Versionado semántico (SemVer) y changelog obligatorio.
- Proceso de release estandarizado con tags firmados.
- Conservación de artefactos y SBOM por versión; política de end-of-life.

5.8 Capacidad para prevenir, encontrar y corregir vulnerabilidades

- Revisiones de código obligatorias con enfoque en seguridad.
- MTTR objetivo para vulnerabilidades por severidad (Crítico/Alto/Medio/Bajo).
- Procedimiento de gestión de vulnerabilidades (identificación, priorización, remediation/mitigation, validación y closure).
- Métricas: % de vulnerabilidades dentro de SLA, tasa de re-apertura, cobertura de escaneo.

CONSIDERACIONES

- Zero Trust: el cliente no es confiable; decisiones de seguridad se basan en tokens verificados y datos del servidor.
- Alinear con los estándares de Arquitectura, Autenticación y Autorización, Codificación Segura, Controles Criptográficos, Logs de Auditoría y Tratamiento de Datos Confidenciales.
- Todo cambio a este estándar requiere revisión de Arquitectura y Seguridad.